

RESOLUTION OF SANCTIONING PROCEDURE

From the procedure instructed by the Spanish Agency for Data Protection and based on the following

BACKGROUND

FIRST: Mr. A.A.A. and Ms. B.B.B. (hereinafter the claimant) filed a complaint with the Spanish Agency for Data Protection on 29/12/2022. The complaint is directed against BANCO SANTANDER, S.A. with NIF A39000013 (hereinafter, the defendant). The reasons for the complaint are as follows:

On 31/03/2005, the claimant acquired a property through a mortgage loan signed with the defendant, which had a duration of 35 years. In the loan deed, in addition to the mortgage guarantee on the property itself and the personal liability of the borrowing purchasers, a mortgage guarantee was also established on a single-family home owned by the company Gardeblock, S.L. (as an additional guarantee for the repayment of the mortgage loan granted). On 27/06/2011, voluntarily, the company Gardeblock, S.L. sold the single-family home that guaranteed the loan operation of the claimant to a third party, allocating part of the amount obtained from the sale to release the outstanding mortgage liability on the claimant's property. On 05/10/2021, the claimant received a court summons from the aforementioned company, demanding payment of the amount that had been paid, despite the fact that the sale was voluntary and the debt was not due until the year 2040. Among the documentation accompanying the summons was a bank certificate issued by the defendant on 25/06/2021, which contained a list with the amortization schedule of the mortgage loan signed by the claimant, covering the period from 21/06/2011 until the end of the loan, that is, the entire period following the release of the liability of Gardeblock, S.L. As a result of what occurred, the claimant filed a complaint with the defendant on ***DATE.1, for providing banking data to third parties unrelated to the operation, receiving a response on ***DATE.2, in which the defendant apologizes for what happened and indicates the following: "We have opened an independent investigation to clarify the facts and, if necessary, take the necessary measures (both disciplinary and procedural) to prevent such events from occurring again. After reviewing the reported facts, we have unfortunately confirmed that, following a formal request for information on the payments made by the company Gardeblock, S.L. regarding a mortgage loan, the branch attached, due to human error, additional information on movements subsequent to the amortization finally made by said company."

Along with the complaint, the claimant provides proof of representation, a copy of the mortgage loan deed, a copy of the certificate and the documentation attached to it (amortization schedule), a copy of the complaint made and the response received, documentation related to the communications maintained with the defendant.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

Claimant requesting economic compensation for what happened and the corresponding responses rejecting any type of compensation.

SECOND: In accordance with Article 65.4 of Organic Law 3/2018, of December 5, on the Protection of Personal Data and Guarantee of Digital Rights (hereinafter LOPDGDD), on 08/02/2023, the aforementioned claim was forwarded to the claimed party, so that they could proceed with its analysis and inform this Agency within one month of the actions taken to comply with the requirements set forth in the data protection regulations.

The forwarding, which was carried out in accordance with the rules established in Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations (hereinafter, LPACAP), was recorded on 09/02/2023 as evidenced by the acknowledgment of receipt in the file.

The claimed party, in a document dated 14/03/2023, stated:

That a loan was granted to the claimant, secured by a mortgage on the property that was the subject of acquisition and that was to be financed; that the aforementioned mortgage loan, in addition to being

secured by the aforementioned property, was also secured by a property owned by the company Gardeblock, S.L., which appeared in the loan deed as a non-debtor mortgagor.

The company Gardeblock, S.L. sold the single-family home, which secured the loan of the claimant up to 94,000 euros in principal, plus ordinary interest, late interest, and costs, according to Clause Nine of the mortgage deed, and proceeded to release the outstanding mortgage liability on the property of Gardeblock, S.L., by paying my represented party the amount of 85,344.01 euros, for which a deed of cancellation of the established mortgage was granted in favor of that entity, according to the certificate issued by the bank attached to the claim.

That upon receiving a judicial claim from that entity, the claimant found among the documentation accompanying the lawsuit a bank certificate issued by the claimed party, which contains a list with the amortization schedule of the mortgage loan subscribed by the claimant, which covered from June 21, 2011, until the loan's conclusion.

For this reason, the claimant filed a complaint against the claimed party for providing banking data to third parties unrelated to the operation.

In response to this complaint, the Privacy Office apologized, stating that measures were being taken to prevent it from happening again, all as a result of erroneous information being produced that extended to movements following the amortization of the loan by the aforementioned company.

The claimants have submitted to the Agency, in addition to the certificate of cancellation of the mortgage from the company Gardeblock, two types of different documents: one identified as Payment Calendar and another as Table of

3/24

issued operations; this second document reflecting the payments of each of the amortization and interest installments should not have been delivered.

THIRD: On 29/03/2023, in accordance with Article 65 of the LOPDGDD, the claim submitted by the claimant was admitted for processing.

FOURTH: On 05/06/2023, the Director of the Spanish Agency for Data Protection agreed to initiate sanctioning proceedings against the respondent for the alleged infringement of Articles 5.1.f) and 32.1 of the GDPR, classified under Articles 83.5.a) and 83.4.a) of the aforementioned GDPR.

FIFTH: Upon notification of the initiation agreement, the respondent submitted a written statement of allegations on 22/06/2023, stating, in summary: that when the incident was known, the internal procedure for managing security breaches was activated, and the review of the actions taken showed that the office employee who ultimately delivered the amortization list initiated and concluded the consultation process with the Department that was supposed to advise her, resulting in a human error in the interpretation of the instructions received; that the delivery of the certificate occurred due to a faulty understanding by the employee, even while being advised, and this was due to the fact that it was not a simple operation, but rather something complex due to the presence in the loan contract of a non-debtor mortgagor who is part of the contract, an error that is understood to occur within the framework of legal relationships in this type of contract; that we are facing an excusable error and not a lack of diligence.

SIXTH: On 07/07/2023, the instructor of the procedure agreed to open a period for the practice of evidence, agreeing to the following:

- To consider the claims filed by the claimants and their documentation as reproduced for evidentiary purposes, as well as the documents obtained and generated by the Inspection Services that are part of the file.
- To consider the allegations to the initiation agreement presented by the respondent and the accompanying documentation as reproduced for evidentiary purposes.

SEVENTH: On 04/04/2024, a Proposal for Resolution was issued stating that the Director of the AEPD should sanction the respondent for the infringement of Articles 5.1.f) and 32.1 of the GDPR, classified under Articles 83.5.a) and 83.4.a) of the GDPR, with fines of €50,000 (fifty thousand euros) and €20,000 (twenty thousand euros), respectively.

Upon notification of the aforementioned Proposal, accepting its content on 08/04/2024, as recorded in the acknowledgment of receipt, the respondent in a letter dated 22/04/2024 indicated that they had opted to proceed with the voluntary payment of the sanctions in consideration of the reductions

provided for in Article 85 of the LPACAP, waiving any administrative appeal, acknowledging their responsibility regarding the facts that led to the procedure.

The respondent attached proof of having made the payment of the sanctions with the double reduction, first, in consideration of the acknowledgment of responsibility, and,

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

4/24

Secondly, for voluntary payment before the resolution of the procedure, reduced to 42,000 euros.

In a written document dated 03/05/2024, the instructor of the procedure informed the summoned party that the acknowledgment of responsibility must be expressed at the beginning of the procedure, during the period for making allegations regarding the opening of the procedure in accordance with the provisions of Article 85 of Law 39/2015, so that the 20% reduction on the sanction would be applicable, unlike the discount for voluntary payment of the sanction, which could be applied when such payment occurs at any time prior to the resolution; that Article 85.2 of the LPACAP expressly and exclusively refers to voluntary payment, and not to the acknowledgment of responsibility, determining that such payment may occur at any time prior to the resolution. Furthermore, Article 85.3 states that "In both cases, when the sanction is solely of a pecuniary nature, the competent authority to resolve the procedure shall apply reductions of at least 20% on the amount of the proposed sanction, which are cumulative. The aforementioned reductions must be specified in the notification of initiation of the procedure and their effectiveness shall be conditioned on the withdrawal or renunciation of any action or appeal in the administrative pathway against the sanction," which would imply that both must be included in the initiation agreement, so it does not contemplate that both reductions are in the resolution proposal or that they can be cumulatively paid at any time prior to the resolution; that based on all this, a period of three days was granted for them to indicate whether they accept or not the only reduction to which they are entitled, indicated in the Resolution Proposal, reduction for voluntary payment of the proposed sanctions before the Resolution is issued, making the corresponding payment.

On 14/05/2024, the summoned party submitted a written statement of allegations in response to the instructor of the procedure, stating in a single allegation that neither in Article 85 of the LPACAP nor in any other provision is there a justification for the limitation that is intended to be applied under section 1 of the aforementioned article, that the ruling of the TS dated 06/10/2022 already indicates that Article 85 indeed establishes and distinguishes two ways to conclude the procedure, however, these ways are not distinguished by the existence of unknown time limits for their exercise but by their subsequent effects, and finally, that the wording of Article 85.3 LPACAP supports the interpretation put forth by the summoned party.

EIGHTH: From the actions taken in the present procedure, the following have been established,

PROVEN FACTS

FIRST. On 29/12/2022, a written document from the complainant was received by the AEPD, in which it is stated that on 31/03/2005, they acquired a property through a mortgage loan signed with the summoned party. In the loan deed, a mortgage guarantee was also established with the company Gardeblock, S.L. on a single-family home owned by that company. On 27/06/2011, voluntarily, the company Gardeblock, S.L. released its outstanding mortgage liability on the complainant's property. On 05/10/2021, the complainant received a judicial demand from the aforementioned company, demanding payment of the...

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

5/24

the amount that had been paid, despite the fact that the sale was voluntary and the debt was not due until the year 2040. Among the documentation accompanying the claim, there was a bank certificate

issued by the defendant on 25/06/2021, which contained a list with the amortization schedule of the mortgage loan subscribed by the claimant, covering from the release of the liability of Gardeblock, S.L. until the completion of the loan. The claimant filed a complaint against the defendant for providing banking data to third parties unrelated to the transaction, receiving a response in which they apologized for what happened and indicated the following: "We have opened an independent investigation to clarify the facts and, if necessary, take the necessary measures (both disciplinary and procedural) to prevent such events from occurring again. After reviewing the reported facts, we have unfortunately confirmed that, following a formal request for information on the payments made by the company Gardeblock, S.L. regarding a mortgage loan, the branch attached, due to human error, additional information on movements subsequent to the amortization finally made by said company."

SECOND. The IDs of the claimants have been submitted.

THIRD. A document issued by the defendant has been submitted in which it STATES:

"(...)

That on November 14, 2011, by means of a public deed granted before Notary D. C.C.C. under number XXX of his protocol, the cancellation of the mortgage charge registered on property number XXXX was granted, following the extraordinary amortization of the previously described loan made for an amount of 85,344.01 euros. The amortization schedule of the loan from that date is attached as an annex to this document.

And for the record, I issue this document at the request of D.D.D. on behalf of Gardeblock, S.L., in Zaragoza on June 21, 2021."

FOURTH. The Issued Operations Table and Payment Schedule of the granted loan have been submitted.

FIFTH. A letter dated 08/11/2021 from the claimant's attorney addressed to the defendant regarding the delivery without consent of confidential financial documentation to a third party (Gardeblock, S.L.), unrelated to the commercial relationship that their representatives maintain with the defendant, used to exercise legal actions unrelated to their interests, has been submitted.

SIXTH. Representation from the claimant's attorney and emails exchanged between the attorney and the defendant dated 04/02/2022, 18/03/2022, and 27/04/2022, in which among other things, economic compensation for the damages caused is requested, have been submitted.

SEVENTH. A letter sent by the defendant to the claimant's attorney, dated 25/01/2022, stating that:

"(...)

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es

6/24

After reviewing the reported facts, we have unfortunately confirmed that following a formal request for information on payments made by the company Gardeblock, S.L., regarding a mortgage loan, the branch attached, due to human error, additional information on movements subsequent to the amortization finally made by said company.

(...)"

EIGHTH. The defendant has submitted Circular C.028/2021, the purpose of which is to inform about the functioning of the Specialized Legal Advisory Units provided to the Network of Offices and other Areas of Santander Spain.

NINTH. The defendant has submitted Circular C.097-2019 with the purpose that Offices that could not obtain the information through Santander tools, the new service of historical data from Popular was created.

TENTH. Screenshots related to the office's actions with the Legal Attention Department of the Business (AJN) have been submitted.

ELEVENTH. An email sent to AJN is recorded, which states the following:

"From: E.E.E. <***EMAIL.1>

(...)

Regarding this matter, I would like to inform you that the company Gardeblock S.L. through the lawyer ... (the powers were verified before informing anything), requested a certificate indicating that the company had amortized in the mortgage of the claimant an amount resulting from the sale of the property that had been ceded to them as collateral. They provided us with sale deeds, a copy of the check, and other documentation. With all that, we requested internal legal advice to indicate what to do, and the response was to request more documentation from historical Popular since we did not have sufficient information.

Everything was requested, and we found a discrepancy in the amount they claimed to have amortized and the one that appeared in historical Popular. We consulted again with legal advice, and they indicated that we should certify with the amount that we had, providing us with the certificate model and the documentation we had to submit, which was the amortization schedule from that date. I attach all the legal advice consultations, as well as all the documentation we have obtained. (...)"

TWELFTH. The defendant has submitted a final report regarding the incident and Risk Analysis; the incident is classified as moderate.

LEGAL GROUNDS

I

Competence

In accordance with the powers granted by Article 58.2 of Regulation (EU) 2016/679 (General Data Protection Regulation, hereinafter GDPR), to each

7/24

The control authority, in accordance with the provisions of Articles 47, 48.1, 64.2, and 68.1 of the Organic Law 3/2018, of December 5, on the Protection of Personal Data and the Guarantee of Digital Rights (hereinafter, LOPDGDD), is competent to initiate and resolve this procedure the Director of the Spanish Agency for the Protection of Data.

Furthermore, Article 63.2 of the LOPDGDD states that: "The procedures processed by the Spanish Agency for the Protection of Data shall be governed by the provisions of Regulation (EU) 2016/679, by this organic law, by the regulatory provisions issued for its development, and, in so far as they do not contradict them, subsidiarily by the general rules on administrative procedures."

II

Preliminary Issue

The party being claimed, notified of the Proposal for Resolution on 08/04/2024, in a document dated 22/04/2024 stated: "That, in accordance with the provisions of the aforementioned Agreement, my represented party has opted to proceed, within the granted period, to the voluntary payment of the sanctions considering the reductions provided for in Article 85 of the LPACAP, with a waiver, in case of acceptance, of any administrative appeal, acknowledging their responsibility regarding the facts that have led to this procedure.

That as evidenced by the transfer receipt, which is attached, my represented party has made the payment of the sanction, with the double reduction provided for in that provision, first, due to the acknowledgment of responsibility and, second, to the reduction applicable for voluntary payment before the resolution of the procedure is issued, provided that at the same time no non-monetary sanction has been imposed, as a result of which the sanction has been reduced to 42,000 euros."

On 03/05/2024, the instructor of the procedure informed the party being claimed that the double reduction was not possible since the acknowledgment of responsibility must be expressed at the beginning of the procedure, during the period for making allegations regarding the opening of the procedure in accordance with what is indicated in Article 85.1 of Law 39/2015, for the 20% reduction on the sanction to be applicable, differentiating it from the reduction for voluntary payment of the sanction, which could be applied when such payment occurs at any time prior to the resolution, and they were granted a period of three days to indicate whether they accepted or not the only reduction to which they were entitled, as indicated in the Proposal for Resolution.

The party being claimed has argued that neither in Article 85 of the LPACAP nor in any other provision is there justification for the limitation that is intended to be applied under the provisions of Article 85.1

of the LPACAP, agreeing that such acknowledgment of responsibility must be made "at the beginning" of the procedure, because that is expressly stated in the cited provision, but what that provision does not state is that such acknowledgment must be made only "at the beginning" of the procedure, which is why this entity cannot accept such an interpretation that it considers.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
8/24

restrictive of their rights and, to strengthen their argument, refers to the ruling of the TS 1260/2022, dated October 6, 2022.

It should be noted that the Resolution Proposal issued on April 4, 2024, in its dispositive part stated that:

"That the Director of the Spanish Agency for Data Protection sanctions BANCO SANTANDER, S.A., with NIF A39000013,

- For the infringement of Article 5.1.f), classified under Article 83.5.a) of the aforementioned GDPR, a fine of €50,000 (fifty thousand euros), and
- For the infringement of Article 32.1 of the GDPR, classified under Article 83.4.a) of the aforementioned GDPR, a fine of €20,000 (twenty thousand euros).

Furthermore, in accordance with the provisions of Article 85.2 of the LPACAP, it is informed that they may, at any time prior to the resolution of this procedure, make voluntary payment of the proposed fine, which will imply a reduction of 20% of the total amount. With the application of this reduction, the fine would be set at €56,000 (fifty-six thousand euros) and its payment will imply the termination of the procedure, without prejudice to the imposition of the corresponding measures. The effectiveness of this reduction will be conditioned upon the withdrawal or renunciation of any action or appeal in the administrative route against the fine."

On the other hand, Article 85, Termination in sanctioning procedures, of the LPACAP establishes that:

"1. Once a sanctioning procedure has been initiated, if the offender acknowledges their responsibility, the procedure may be resolved with the imposition of the appropriate sanction.

2. When the sanction is solely pecuniary or when it is possible to impose a pecuniary sanction and another non-pecuniary sanction but the impropriety of the latter has been justified, voluntary payment by the alleged responsible party, at any time prior to the resolution, will imply the termination of the procedure, except regarding the restoration of the altered situation or the determination of compensation for damages caused by the commission of the infringement.

3. In both cases, when the sanction is solely pecuniary, the competent authority to resolve the procedure will apply reductions of at least 20% on the amount of the proposed sanction, which are cumulative. The aforementioned reductions must be specified in the notification of the initiation of the procedure and their effectiveness will be conditioned upon the withdrawal or renunciation of any action or appeal in the administrative route against the sanction. The percentage of reduction provided in this section may be increased by regulation.

The acknowledgment of responsibility, as indicated in the Initiation Agreement, must be expressed once the procedure has been initiated, during the period for submitting allegations to the opening of the procedure. This is in accordance with the provisions of the aforementioned Article 85 of Law 39/2015, according to which the acknowledgment of responsibility must occur "once the procedure has been initiated" for it to be applicable."

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
9/24

proposed reduction of 20% on the penalty, unlike what is expressly established regarding the discount for voluntary payment of the penalty, which may be applied when such payment occurs at any time prior to the resolution. If the aforementioned provision has distinguished the conditions in the two

modes of voluntary termination of the procedure indicated, no interpretation should equate these conditions as if there were no differences in their regulation.

Article 85.2 of the LPACAP refers expressly and solely to voluntary payment, and not to the acknowledgment of responsibility, determining that such payment may occur at any time prior to the resolution. Thus, one cannot distinguish or impose where the Law does not distinguish or impose. Furthermore, Article 85.3 indicates that "In both cases, when the penalty is solely of a pecuniary nature, the competent authority to resolve the procedure shall apply reductions of at least 20% on the amount of the proposed penalty, which shall be cumulative. The aforementioned reductions must be specified in the notification of initiation of the procedure, and their effectiveness shall be conditioned upon the withdrawal or renunciation of any action or appeal in the administrative pathway against the penalty," which implies that both must be included in the initiation agreement (referring from Article 85.1 to Article 64 of the LPACAP), so it does not contemplate that both reductions are in the resolution proposal or that they can be cumulatively paid at any time prior to the resolution.

This is also understood by the National Court, Administrative Litigation Chamber, Section 1, which in its Judgment of 05/02/2021, Rec. 41/2019, indicates that voluntary payment can occur at any time prior to the resolution, while the reduction for acknowledgment of responsibility is linked to the initiation agreement and to the provision of Article 64.2.d) of Law 39/2015: "Regarding the infringement of the provisions in Articles 64 and 85 of Law 39/2015, which contemplate the possibility of acknowledging responsibility at the time of notification of the initiation resolution of the procedure (art. 64.2.d) and availing oneself of the reductions provided in Article 85, in the initiation agreement of the procedure there is an express reference to those articles, indicating that paragraphs 2 and 3 of Article 85 do not apply; moreover, at no time has the claimant shown their willingness to acknowledge responsibility for the sanctioned infringement and avail themselves of the possibility established in those articles (voluntary payment can be made at any time prior to the resolution), therefore this allegation must also be dismissed."

Finally, regarding STS 1260/2022, of 06/10/2022, although related to what is being elucidated in the present sanctioning procedure, the issue submitted for debate in the Fifth Section of the Administrative Litigation Chamber of the Supreme Court was a completely different matter: to determine whether the expiration of the procedure had indeed occurred due to the lapse of the established time for its processing, and linked to the above, whether it should be understood that the procedure had concluded with the advance payment, with the 20% reduction, which had been accepted by the sanctioned party, without the need for a further express resolution, or whether, on the contrary, the termination of the procedure does not occur until an express act is issued bringing it to an end, that is, with the agreement of the Council of Ministers that is the subject of challenge in this process.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

10/24

Furthermore, in Foundation One, Object of the appeal, it is stated that: "(...) The proposed resolution includes the facts and qualifications previously stated, although the amount of the liability incurred to the public domain is reduced, being notified to the interested party on April 19, 2021. The following day, on May 14, the sanctioned party submitted a written statement in which they accepted the facts attributed to them, availing themselves of the option for voluntary payment of the proposed sanction, with a 20% reduction, and a payment letter was issued by the Basin Organization, which was attended to by the sanctioned party (the underlining is from the AEPD). (...)".

Therefore, the allegations made by the responding party in their written statement of 14/05/2024, requesting the acceptance of the reductions sought after the issuance of the Proposal for Resolution, are not accepted, and it cannot be considered that the interested party has legally availed themselves of either of the two reductions provided for in the aforementioned Article 85, meaning they must pay the total amount of the fines corresponding to the infringements committed, without any reduction, in accordance with what is stated in the dispositive part of this Resolution.

III

First obligation breached: infringement of Article 5.1.f) of the GDPR

The claimed facts materialize in the access to the data of the claimant, as a consequence of the information transmitted to a third party by the respondent in relation to a mortgage loan subscribed by the claimant, which could lead to a violation of the regulations regarding the protection of personal data.

Article 5 of the GDPR, Principles relating to processing, establishes that:

“1. Personal data shall be:

(...)”

f) processed in such a way as to ensure an adequate security of personal data, including protection against unauthorized or unlawful processing and against accidental loss, destruction, or damage, by means of appropriate technical or organizational measures (“integrity and confidentiality”).

(...)”

Furthermore, Recital 39 states that “All reasonable measures must be taken to ensure that personal data that are inaccurate are rectified or deleted. Personal data must be processed in a manner that ensures adequate security and confidentiality of personal data, including to prevent unauthorized access or use of such data and the equipment used in the processing.”

The documentation in the file provides clear indications that the respondent has violated Article 5 of the GDPR, principles relating to processing, regarding the principle of confidentiality of the data contained in paragraph 1, letter f), by being communicated to a third party, a non-debtor mortgagor, a list containing the amortization schedule of the mortgage loan subscribed by the claimant, violating the duty of confidentiality and integrity of the data.

This duty must be understood as aimed at preventing unauthorized leaks of data by the data subjects and is regulated in the cited article referring to the principle of integrity and confidentiality as one of the principles of data protection:

In the response provided to the information request made by the AEPD on 13/03/2023, confirmed in the written allegations to the initiation agreement, the respondent stated: “On October 5, 2021, the claimant received a court summons from the aforementioned company, demanding payment of the amount that had been paid, despite the fact that the sale was voluntary and the debt was not due until the year 2040.

Among the documentation accompanying the summons was a bank certificate issued by the respondent on June 25, 2021, which contained a list with the amortization schedule of the mortgage loan subscribed by the claimant, covering from June 21, 2011, until the end of the loan, that is, the entire period following the release of the liability of Gardeblock, S.L.”

And in a written statement dated 21/06/2023, it was stated that “there has been an improper delivery of data by the person responsible for delivering the certificate that gives rise to these proceedings due to their defective understanding of the advice received regarding a complex contractual relationship” (the underlining corresponds to the AEPD).

Additionally, in the Report prepared following the incident, it is indicated that “from the moment the Bank releases the property owned by Gardeblock from liability, it must be considered excessive to provide information regarding the contract and its movements from that date, as it has occurred.”

The duty of confidentiality is an obligation that pertains not only to the data controller and processor but to anyone involved in any phase of the processing and is complementary to the duty of professional secrecy.

Therefore, the action taken by the respondent allowing access to the banking information of the claimant by a third party constitutes a violation of Article 5.1.f) of the GDPR, an infringement classified in Article 83.5.a) of the aforementioned GDPR.

IV

Qualification of the infringement of Article 5.1.f) of the GDPR

The infringement attributed to the respondent is classified in Article 83.5 a) of the GDPR, which considers that the infringement of “the basic principles for processing, including the conditions for consent in accordance with the...

12/24

Articles 5, 6, 7, and 9” is punishable, in accordance with paragraph 5 of the aforementioned Article 83 of the cited Regulation, “with administrative fines of up to €20,000,000 or, in the case of a company, an amount equivalent to a maximum of 4% of the total annual global turnover of the previous financial year, opting for the higher amount.”

The LOPDGDD in its Article 71, Offenses, states that: “Acts and behaviors referred to in paragraphs 4, 5, and 6 of Article 83 of Regulation (EU) 2016/679, as well as those that are contrary to this organic law, constitute offenses.”

And in its Article 72, it considers for the purposes of prescription, that they are: “Very serious offenses:

1. According to what is established in Article 83.5 of Regulation (EU) 2016/679, the following are considered very serious and will prescribe after three years: offenses that constitute a substantial violation of the articles mentioned therein and, in particular, the following:

(...)

a) The processing of personal data violating the principles and guarantees established in Article 5 of Regulation (EU) 2016/679.

(...)”

V

Sanction for the violation of Article 5.1.f) of the GDPR

In order to establish the administrative fine that should be imposed, the provisions contained in Articles 83.1 and 83.2 of the GDPR must be observed, which state:

“1. Each supervisory authority shall ensure that the imposition of administrative fines under this article for the violations of this Regulation indicated in paragraphs 4, 5, and 6 are, in each individual case, effective, proportionate, and dissuasive.

2. Administrative fines shall be imposed, depending on the circumstances of each individual case, as an additional or substitute measure to those contemplated in Article 58, paragraph 2, letters a) to h) and j). In deciding on the imposition of an administrative fine and its amount in each individual case, the following shall be duly taken into account:

- a) the nature, gravity, and duration of the infringement, taking into account the nature, scope, or purpose of the processing operation in question as well as the number of data subjects affected and the level of damage and harm they have suffered;
- b) the intentionality or negligence in the infringement;
- c) any measures taken by the controller or processor to mitigate the damage and harm suffered by the data subjects;
- d) the degree of responsibility of the controller or processor, taking into account the technical or organizational measures they have implemented pursuant to Articles 25 and 32;
- e) any previous infringements committed by the controller or processor;
- f) the degree of cooperation with the supervisory authority in order to remedy the infringement and mitigate the possible adverse effects of the infringement;
- g) the categories of personal data affected by the infringement;
- h) the manner in which the supervisory authority became aware of the infringement, in particular, whether the controller or processor notified the infringement and, if so, to what extent;
- i) when the measures indicated in Article 58, paragraph 2, have been previously ordered against the controller or processor in relation to the same matter, the compliance with such measures;
- j) adherence to codes of conduct under Article 40 or to certification mechanisms approved under Article 42, and

k) any other aggravating or mitigating factor applicable to the circumstances of the case, such as the financial benefits obtained or the losses avoided, directly or indirectly, through the infringement.”

In relation to letter k) of Article 83.2 of the GDPR, the LOPDGDD, in its Article 76, “Sanctions and corrective measures,” establishes that:

“2. According to the provisions of Article 83.2.k) of Regulation (EU) 2016/679, the following may also be taken into account:

- a) The continued nature of the infringement.
- b) The connection of the infringer's activity with the processing of personal data.

- c) The benefits obtained as a result of the commission of the infringement.
- d) The possibility that the conduct of the affected party may have induced the commission of the infringement.
- e) The existence of a merger by absorption after the commission of the infringement, which cannot be attributed to the absorbing entity.
- f) The impact on the rights of minors.
- g) Having, when not mandatory, a data protection officer.
- h) The voluntary submission by the controller or processor to alternative dispute resolution mechanisms, in cases where there are disputes between them and any data subject.”

- In accordance with the transcribed provisions, and without prejudice to what results from the instruction of the procedure, for the purpose of determining the amount of the sanction to be imposed in this case for the infringement of Article 5.1.f) of the GDPR, classified in Article 83.5.a) of the GDPR for which the respondent is responsible, an initial assessment considers the following factors as aggravating circumstances:

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
14/24

The nature, severity, and duration of the infringement, taking into account the nature, scope, or purpose of the processing operation in question; the facts revealed affect a basic principle regarding the processing of personal data, such as the confidentiality of the same, which the regulation penalizes with the utmost severity by enabling access to a third party who was not authorized, with the harm that this may entail since the banking information provided was used by the aforementioned company (the third party), attaching it to the legal claim against the claiming party, demanding payment of the amount that had been paid (Article 83.2, a) of the GDPR).

The activity of the allegedly infringing entity is linked to the processing of data from both clients and third parties. In the activity of the claimed entity, the processing of personal data of its clients is essential, so given its business volume, the significance of the conduct subject to this claim is undeniable (Article 76.2.b) of the LOPDGDD in relation to Article 83.2.k).

The intentionality or negligence in the infringement; there is a serious lack of diligence in the actions of the claimed party since the transfer of information to a third party constitutes an unlawful act for which it was not authorized. Also connected with the degree of diligence that the data controller is obliged to exercise in compliance with the obligations imposed by data protection regulations, the SAN of 17/10/2007 can be cited. Although it was issued before the entry into force of the GDPR, its ruling is perfectly extrapolable to the case we are analyzing. The judgment, after referring to the fact that entities whose activities involve continuous processing of data from clients and third parties must observe an adequate level of diligence, specified that “(...) the Supreme Court has understood that there is negligence whenever a legal duty of care is neglected, that is, when the infringer does not behave with the required diligence. And in assessing the degree of diligence, the professionalism or lack thereof of the subject must be especially weighed, and there is no doubt that, in the case now examined, when the activity of the appellant involves constant and abundant handling of personal data, it must be insisted upon the rigor and exquisite care to comply with the legal provisions in this regard” (Article 83.2, b) of the GDPR).

The business volume of the claimed party, as it is one of the leading financial entities within the Spanish market, due to its business purpose (Article 83.2, k) of the GDPR).

In accordance with the above, it is deemed appropriate to establish a sanction of 50,000 euros for the violation of Article 5.1.f) of the GDPR.

VI

Second obligation breached: infringement of Article 32.1 of the GDPR

Article 32 of the GDPR “Security of processing” establishes that:

“1. Taking into account the state of the art, the costs of implementation, and the nature, scope, context,

and purposes of the processing, as well as the risks of varying probability and severity for the rights and freedoms of individuals...

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
15/24

In the case of physical data, the data controller and the data processor shall apply appropriate technical and organizational measures to ensure a level of security appropriate to the risk, which may include, among others:

- a) the pseudonymization and encryption of personal data;
- b) the ability to ensure the ongoing confidentiality, integrity, availability, and resilience of processing systems and services;
- c) the ability to restore the availability and access to personal data quickly in the event of a physical or technical incident;
- d) a process for regular verification, evaluation, and assessment of the effectiveness of the technical and organizational measures to ensure the security of processing.

2. In assessing the adequacy of the level of security, particular consideration shall be given to the risks presented by the processing of data, in particular as a consequence of the accidental or unlawful destruction, loss, or alteration of personal data transmitted, stored, or otherwise processed, or the unauthorized communication or access to such data.

3. Adherence to an approved code of conduct pursuant to Article 40 or to an approved certification mechanism pursuant to Article 42 may serve as a means to demonstrate compliance with the requirements set out in paragraph 1 of this article.

4. The data controller and the data processor shall take measures to ensure that any person acting under the authority of the controller or the processor and having access to personal data may only process such data on instructions from the controller, unless required to do so by Union or Member State law.”

The GDPR defines personal data security breaches as “all breaches of security that result in the accidental or unlawful destruction, loss, or alteration of personal data transmitted, stored, or otherwise processed, or unauthorized communication or access to such data.”

The documentation in the file provides clear evidence that the respondent has violated Article 32.1 of the GDPR, as a security incident occurred due to a lack of diligence in complying with the implemented technical and organizational measures.

It should be noted that the GDPR in the aforementioned provision does not establish a list of security measures applicable according to the data being processed, but rather states that the controller and the processor shall apply technical and organizational measures that are appropriate to the risk posed by the processing, taking into account the state of the art, the costs of implementation, the nature, scope, context, and purposes of the processing, and the risks of likelihood and severity for the rights and freedoms of the data subjects.

Furthermore, the security measures must be adequate and proportionate to the identified risk, indicating that the determination of the measures...

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
16/24

Technical and organizational measures must be carried out taking into account: pseudonymization and encryption, the ability to ensure confidentiality, integrity, availability, and resilience, the ability to restore availability and access to data after an incident, verification process (which is not an audit), evaluation,

and assessment of the effectiveness of the measures.

In any case, when assessing the adequacy of the security level, particular attention shall be paid to the risks presented by the data processing, such as the destruction, loss, or accidental or unlawful alteration of personal data transmitted, stored, or otherwise processed, or the unauthorized communication or access to such data that could cause physical, material, or immaterial harm.

In this same sense, Recital 83 of the GDPR states that:

“(83) In order to maintain security and prevent processing from infringing the provisions of this Regulation, the controller or processor must assess the inherent risks of the processing and implement measures to mitigate them, such as encryption. These measures must ensure an adequate level of security, including confidentiality, taking into account the state of the art and the cost of their implementation in relation to the risks and the nature of the personal data that must be protected.

When assessing the risk in relation to data security, the risks arising from the processing of personal data must be taken into account, such as the destruction, loss, or accidental or unlawful alteration of personal data transmitted, stored, or otherwise processed, or the unauthorized communication or access to such data, particularly susceptible to causing physical, material, or immaterial harm.”

- In the case analyzed, as stated in the facts and within the framework of the investigation file, the AEPD forwarded the complaint presented to the respondent for analysis, requesting the provision of information related to the claimed incident, confirming in its response the transfer of the bank certificate to the third party requesting it, the non-debtor mortgagor.

In this way, the respondent indicated that “In relation to this, upon receiving the complaint from the interested parties, after reviewing the reported facts, a response is provided confirming that, unfortunately, the branch has mistakenly attached additional information regarding movements subsequent to the amortization finally carried out by said company, extending our sincerest apologies, as evidenced by the response from the Privacy Office that the complainants attach to their complaint.” It has also stated that “it is evident that the Bank has taken the necessary actions to fulfill the obligation to implement appropriate measures to ensure an adequate level of security in relation to the risk of processing, although in this specific case it has not been possible to avoid an unintended outcome due to reasons beyond the process.”

It should be noted that the responsibility of the respondent is determined by the failure to adopt the appropriate care and agility that would have prevented errors such as the one mentioned.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

17/24

indicated, as it is responsible for making decisions aimed at effectively implementing and adapting the appropriate organizational measures to ensure an adequate level of security relative to the risk to safeguard the confidentiality of the data, restoring its availability and preventing access to it in the event of a physical or technical incident.

In the email dated 09/11/2021 sent to Judicial Communications Adm, it is stated that:

“(…)

With all that, we requested internal legal advice to indicate what to do, and the response was that we should request more documentation from historical popular since we did not have sufficient information.

Everything was requested, and we found a discrepancy in the amount they claimed to have amortized and the amount that appeared in historical popular. We consulted again with legal advice, and they indicated that we should certify with the amount that appeared to us, providing us with the model of the certificate and the documentation that we had to submit to them, which was the amortization table from that date.

I attach all the inquiries from legal advice, as well as all the documentation we have obtained.

(…)”.

What does not align with what is indicated by the responding party in the Report on the incident that

occurred when it states: "(...) This process is implemented and its normal functioning is confirmed, verifying that it is used by the offices appropriately (in the incident we are analyzing, the employee has observed the existing procedure), so it can be concluded that there is a diligent and adequate measure to the risk at Banco Santander that guarantees that in the issuance of this type of certificates, there is no accidental or fortuitous access of personal data to an incorrect recipient, so in this incident, a regrettable human, conceptual, and punctual error occurred in the interpretation of the received instructions and, specifically, regarding who the holders of the mortgage loan were.

However, from the aforementioned communication, it follows that in the face of the doubt or discrepancy expressed due to the amortized amount not matching the amount of the received checks, the acting branch again requested advice from the AJN department and was indicated the certificate they had to issue, providing them with the model of the same and the documentation they had to attach with it: the amortization table from that date (the underlines are from the AEPD).

It is true that the certificate delivered did not affect its content from the initial part of the amortization table, from the beginning of the loan until the moment of amortization by the company Gardeblock, S.L. to which the complete certificate was delivered, thus legitimizing it to have and receive it until that date, but certainly not, from that date, to receive the information of the amortization schedule subsequent to the moment in which the company had made the payment releasing its property from mortgage liability.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
18/24

The measures established must be necessary to prevent this type of incident from occurring and must strictly adhere to the procedures implemented by the entity to avoid them, as it ultimately concerns preserving the confidentiality of the data in the actions and operations of its clients.

The respondent must have a protocol, procedure, etc., that when implemented can guarantee the security in the processing of information and data and that prevents unauthorized access to them. In the present case, this situation has not occurred since the measures adopted have not guaranteed that in the issuance of the certificate, there was no access to personal data by an unauthorized recipient, the third party, being provided with undue information.

Therefore, the implementation of measures must consider the impact that an incident could have on rights and freedoms, whether it occurs accidentally, humanly, naturally, or technologically, and must aim to reduce both the impact and the probability of such incidents, which must be in constant renewal and improvement.

- The respondent also argues that the ruling of the Supreme Court (T.S.) of 15/02/2022 clearly establishes that the obligation to adopt technical and organizational measures aimed at ensuring confidentiality is an obligation of means and not of results.

The respondent acknowledges that in its actions, the existence of the security incident arose from mistakenly attaching additional information regarding the subsequent movements after the amortization finally carried out by the company - the third party in dispute.

It is true that the T.S. in its ruling states that: "The obligation to adopt the necessary measures to ensure the security of personal data cannot be considered an obligation of result, which implies that once a personal data breach occurs to a third party, there is liability regardless of the measures adopted and the activity carried out by the data controller or processor.

In obligations of result, there is a commitment to achieve a specific objective, ensuring the achievement or proposed result, in this case, guaranteeing the security of personal data and the non-existence of breaches or security failures.

In obligations of means, the commitment undertaken is to adopt the technical and organizational means, as well as to deploy diligent activity in their implementation and use that aims to achieve the expected result with means that can reasonably be deemed adequate and sufficient for its attainment; hence they are referred to as "diligence" or "behavior" obligations.

The difference lies in the liability in each case, as while in the obligation of result one is liable for a harmful result due to a security system failure, whatever its cause and the diligence used. In the obligation of means, it is sufficient to establish technically adequate measures and implement and use them with reasonable diligence.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es

19/24

In these latter obligations, the sufficiency of the security measures that the responsible party must establish must be related to the state of technology at any given moment and the level of protection required concerning the personal data processed, but a result is not guaranteed.”
But it is also true that the Court confirms that the design of the necessary technical and organizational means is not sufficient, as their correct implementation and appropriate use are also necessary, to which must be added diligent action that has not occurred in the present case.
Therefore, in accordance with the above, it is considered that the respondent would be liable for the infringement of Article 32.1 of the GDPR, an infringement classified in its Article 83.4.a).

IX

Classification of the infringement of Article 32.1 of the GDPR

The violation of Article 32 of the GDPR is classified in Article 83.4.a) of the aforementioned GDPR in the following terms:

“4. Violations of the following provisions shall be sanctioned, in accordance with paragraph 2, with administrative fines of up to 10,000,000 EUR or, in the case of a company, an amount equivalent to a maximum of 2% of the total annual global turnover of the previous financial year, opting for the higher amount:

a) the obligations of the controller and the processor under Articles 8, 11, 25 to 39, 42, and 43.
(...)”

For its part, the LOPDGDD in its Article 73, for the purposes of prescription, qualifies as “Serious Violations”:

“According to what is established in Article 83.4 of Regulation (EU) 2016/679, the following are considered serious and shall prescribe after two years the violations that constitute a substantial breach of the articles mentioned therein and, in particular, the following:

(...)”

g) The breach, as a result of a lack of due diligence, of the technical and organizational measures that should have been implemented in accordance with the requirements of Article 32.1 of Regulation (EU) 2016/679.”

(...)”

VIII

In order to establish the administrative fine that should be imposed, the provisions contained in Articles 83.1 and 83.2 of the GDPR must be observed, which state:

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es

20/24

“1. Each supervisory authority shall ensure that the imposition of administrative fines under this article for the infringements of this Regulation indicated in paragraphs 4, 5, and 6 are, in each individual case, effective, proportionate, and dissuasive.

2. Administrative fines shall be imposed, depending on the circumstances of each individual case, as an additional or substitute measure to those provided for in Article 58, paragraph 2, letters a) to h) and j). In deciding the imposition of an administrative fine and its amount in each individual case, the following shall be duly taken into account:

- a) the nature, gravity, and duration of the infringement, taking into account the nature, scope, or purpose of the processing operation in question as well as the number of data subjects affected and the level of damage and harm they have suffered;
- b) the intentionality or negligence in the infringement;
- c) any measures taken by the controller or processor to mitigate the damage and harm suffered by the data subjects;
- d) the degree of responsibility of the controller or processor, taking into account the technical or organizational measures they have implemented pursuant to Articles 25 and 32;
- e) any previous infringement committed by the controller or processor;
- f) the degree of cooperation with the supervisory authority in order to remedy the infringement and mitigate the possible adverse effects of the infringement;
- g) the categories of personal data affected by the infringement;
- h) the manner in which the supervisory authority became aware of the infringement, in particular whether the controller or processor notified the infringement and, if so, to what extent;
- i) when the measures indicated in Article 58, paragraph 2, have been previously ordered against the controller or processor in relation to the same matter, the compliance with such measures;
- j) adherence to codes of conduct under Article 40 or to certification mechanisms approved under Article 42, and
- k) any other aggravating or mitigating factor applicable to the circumstances of the case, such as the financial benefits obtained or the losses avoided, directly or indirectly, through the infringement.”

In relation to letter k) of Article 83.2 of the GDPR, the LOPDGDD, in its Article 76, “Sanctions and corrective measures,” establishes that:

“2. In accordance with the provisions of Article 83.2.k) of Regulation (EU) 2016/679, the following may also be taken into account:

- a) The continued nature of the infringement.
- b) The connection of the infringer's activity with the processing of personal data.
- c) The benefits obtained as a result of the commission of the infringement.
- d) The possibility that the conduct of the affected party may have induced the commission of the infringement.”

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

21/24

- e) The existence of a merger by absorption after the commission of the infringement, which cannot be attributed to the absorbing entity.
- f) The impact on the rights of minors.
- g) To have, when not mandatory, a data protection officer.
- h) The voluntary submission by the responsible party or processor to alternative dispute resolution mechanisms, in cases where there are disputes between them and any interested party.

In accordance with the transcribed provisions, and without prejudice to what results from the instruction of the procedure, for the purpose of determining the amount of the sanction to be imposed in this case for the infringement of Article 32.1 of the GDPR, classified under Article 83.4.a) of the GDPR for which the respondent is held responsible, an initial assessment considers the following factors as aggravating circumstances:

The nature and severity of the infringement; the facts revealed affect a basic principle related to the processing of personal data, namely the security of such data, the infringement of which is severely sanctioned by the regulation; on the other hand, the management and purpose of the processing carried out is questioned by allowing access to the claimant's data, economic data, as a result of the communication to a third party of information related to the mortgage loan subscribed by the claimant with the entity, which in no case should have been transmitted given the harm it could cause as a consequence of such delivery, as highlighted by the claimant when it was used by the third party,

providing it in a judicial demand against the claimant (Article 83.2.a) of the GDPR).

The activity of the allegedly infringing entity is linked to the processing of data of both clients and third parties. In the activity of the responding entity, the processing of personal data of its clients is essential, so given the volume of business of the same, the significance of the conduct subject to this claim is undeniable (Article 76.2.b) of the LOPDGDD in relation to Article 83.2.k).

The intentionality or negligence in the infringement; there is a serious lack of diligence in the actions of the respondent since the transfer of information to a third party constitutes an unlawful act for which it was not authorized, violating organizational measures. Also connected with the degree of diligence that the data controller is obliged to exercise in compliance with the obligations imposed by data protection regulations, the SAN of 17/10/2007 can be cited. Although it was issued before the entry into force of the GDPR, its ruling is perfectly extrapolable to the case we are analyzing. The ruling, after referring to the fact that entities whose activities involve continuous processing of data of clients and third parties must observe an adequate level of diligence, specified that "(...). the Supreme Court has understood that there is negligence whenever a legal duty of care is disregarded, that is, when the infringer does not behave with the required diligence. And in assessing the degree of diligence, the professionalism or lack thereof of the subject must be especially weighed, and there is no doubt that, in the case now examined, when the activity of the appellant is constant and...

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
22/24

The abundant handling of personal data must emphasize the rigor and exquisite care to comply with the legal provisions in this regard" (Article 83.2, b) of the GDPR).

The volume of business of the respondent is that it is one of the leading financial entities within the Spanish market, due to its business purpose (Article 83.2, k) of the GDPR).

In accordance with the above, it is deemed appropriate to establish a sanction of 20,000 euros for the violation of Article 32.1 of the GDPR.

X

The corrective powers that the GDPR attributes to the AEPD as the supervisory authority are detailed in Article 58.2, paragraphs a) to j).

Upon confirming the violations committed, it is appropriate to agree to impose on the responsible party the adoption of adequate measures to adjust its actions to the regulations mentioned in this act, in accordance with the provisions of the aforementioned Article 58.2 d) of the GDPR, according to which each supervisory authority may "order the controller or processor to ensure that the processing operations comply with the provisions of this Regulation, where appropriate, in a specified manner and within a specified time frame...". The imposition of this measure is compatible with the sanction consisting of an administrative fine, as provided in Article 83.2 of the GDPR.

Therefore, it would be considered appropriate to order that the respondent, within six months from the finality of the sanctioning resolution, which in any case will be issued, adjust the processing activities subject to this procedure to the applicable regulations. The text of this agreement establishes what the facts have been that led to the violation of data protection regulations, from which it is clearly inferred what measures are to be adopted, without prejudice to the fact that the type of procedures, mechanisms, or specific instruments for implementing them corresponds to the sanctioned party, as it is the one who fully knows its organization and must decide, based on proactive responsibility and a risk-based approach, how to comply with the GDPR and the LOPDGDD. It is true that the interested party states that it has updated the incident register with details regarding the data security breach; however, in this case, it is noted among other measures to be adopted the improvement of those already implemented to prevent incidents like the one that occurred, ensuring that in the issuance of this type of certificates, there are no accesses to personal data by third parties or unauthorized recipients.

Therefore, in accordance with the applicable legislation and assessed the criteria for the graduation of

the sanctions whose existence has been established,

The Director of the Spanish Agency for Data Protection RESOLVES:

FIRST: TO IMPOSE on BANCO SANTANDER, S.A., with NIF A39000013,

- For a violation of Article 5.1.f) of the GDPR, classified under Article 83.5.a) of the GDPR, a fine of 50,000 € (fifty thousand euros).

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

23/24

-

For a violation of Article 32.1 of the GDPR, classified under Article 83.4.a) of the GDPR, a fine of €20,000 (twenty thousand euros).

SECOND: ORDER BANCO SANTANDER, S.A., with NIF A39000013, to, pursuant to Article 58.2.d) of the GDPR, within six months from the date the resolution becomes final and enforceable, demonstrate that it has improved the measures implemented to prevent incidents like the one that occurred, ensuring that in the issuance of certificates, there are no accesses to personal data by third parties or unauthorized recipients, in accordance with the provisions of Article 5.1.f) and 32.1 of the GDPR.

THIRD: NOTIFY this resolution to BANCO SANTANDER, S.A.

FOURTH: This resolution will be enforceable once the period for filing the optional appeal for reconsideration (one month from the day following the notification of this resolution) has expired without the interested party having exercised this right. The sanctioned party is warned that they must pay the imposed sanction once this resolution is enforceable, in accordance with the provisions of Article 98.1.b) of Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations (hereinafter LPACAP), within the voluntary payment period established in Article 68 of the General Collection Regulation, approved by Royal Decree 939/2005, of July 29, in relation to Article 62 of Law 58/2003, of December 17, by making the payment, indicating the NIF of the sanctioned party and the procedure number that appears in the heading of this document, into the restricted account No. IBAN: ES00 0000 0000 0000 0000 0000 (BIC/SWIFT Code: XXXXXXXXXXXX), opened in the name of the Spanish Agency for Data Protection at the banking entity CAIXABANK, S.A. Otherwise, collection will proceed during the executive period.

Upon receipt of the notification and once enforceable, if the date of enforceability falls between the 1st and the 15th of each month, inclusive, the deadline for voluntary payment will be until the 20th of the following month or the next business day, and if it falls between the 16th and the last day of each month, inclusive, the payment deadline will be until the 5th of the second following month or the next business day.

In accordance with the provisions of Article 50 of the LOPDGDD, this Resolution will be made public once it has been notified to the interested parties.

Against this resolution, which concludes the administrative process in accordance with Article 48.6 of the LOPDGDD, and in accordance with the provisions of Article 123 of the LPACAP, the interested parties may optionally file an appeal for reconsideration before the Director of the Spanish Agency for Data Protection within one month from the day following the notification of this resolution or directly file a contentious-administrative appeal before the Contentious-Administrative Chamber of the National Court, in accordance with the provisions of Article 25 and Section 5 of the fourth additional provision of Law 29/1998, of July 13, regulating the Contentious-Administrative Jurisdiction, within two months from the day following the notification of this act, as provided in Article 46.1 of the aforementioned Law.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

24/24

Finally, it is noted that in accordance with the provisions of Article 90.3 a) of the LPACAP, the firm

resolution in the administrative process may be provisionally suspended if the interested party expresses their intention to file a contentious-administrative appeal. If this is the case, the interested party must formally communicate this fact by means of a written document addressed to the Spanish Agency for Data Protection, submitting it through the Electronic Registry of the Agency [<https://sedeagpd.gob.es/sede-electronica-web/>], or through any of the other registries provided for in Article 16.4 of Law 39/2015, of October 1. They must also provide the Agency with documentation that proves the effective filing of the contentious-administrative appeal. If the Agency is not aware of the filing of the contentious-administrative appeal within two months from the day following the notification of this resolution, it will consider the provisional suspension to be concluded.

Mar España Martí

Director of the Spanish Agency for Data Protection

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es